Mandate Wallet security self-assessment

Mandate Labs | 20 October 2026 | Author assessment for a testnet engineering release

1. Assessment scope

This report covers the deployed-account payment route, local gateway, MCP integrations, owner workspace, onboarding, evidence verifier and controlled experiments. It is an engineering self-assessment. Independent static-tool review has a separate recorded scope and does not constitute a third-party human audit or certification.

Protected assets include owner-controlled tokens, finite session permissions, connection and signing credentials, the identity of a purchase and its original transaction, and the integrity of disclosed evidence. An attacker may control prompts, catalog descriptions, concurrent requests, a session key or local records. Financial safety assumes a trusted owner key/interface, correct cryptography and token behavior, and canonical chain observations. A same-user or administrator process may read local session keys and alter local records.

The accepted route is x402 v2 exact/EIP-3009 through a deployed ERC-1271 account. Base Sepolia native test USDC and controlled Ethereum Sepolia fixtures have distinct evidence. Mainnet payments, Permit2, ERC-7710, arbitrary merchants and production remote custody are outside the supported release.

2. Roles and enforceable authority

The owner creates and changes root policies and sessions, withdraws funds and revokes authority. In the recorded Base Sepolia flow the owner key remained in external Rabby, and native Claude Desktop invoked the MCP tools. This actual path complements historical MetaMask and local tests. It does not establish all-device or mobile usability acceptance.

A session key signs a concrete registration and token payment within a grant. A connection credential selects a fixed local profile and permits tool access. It is not an owner key or a chain grant. Rotating that credential does not revoke an already authorized chain payment.

Registration and settlement gas roles submit signed operations without expanding their authority. The merchant signs configured claims and returns data. The verifier checks disclosed data against separately trusted scope and RPCs. Optional controller limits apply at that controller's interface. These roles do not become independent security domains merely because they use different keys on one machine.

3. Financial safety and recovery

Registration atomically reserves both root and session budget before the client exposes a payment signature. One permanent used-step flag and a deterministic chain/wallet/root/step nonce prevent the same business step from registering again through another session or version. The ERC-1271 settlement check re-evaluates current version, epoch, revocation, expiry and exact registered parameters.

Paid, pending and uncertain amounts remain occupied. Automatic release requires an expired payment with an unused token nonce. A consumed-unknown nonce remains unresolved. Reservation does not escrow the token balance, and budgets on different chains are independent. Owner withdrawal, insufficient cash, token upgrades or prolonged RPC outages can prevent delivery even when scope was valid.

The durable client stores the original intent and signed transaction before broadcast. Timeouts reconcile the original hash and nonce. Reorg handling checks canonical block hashes and retains earlier evidence. Recovery never silently creates a new payment nonce. A successful settlement cannot be refunded by a later revocation. Failed operations may still cost gas.

4. Threat, control and residual risk

Threat	Implemented control and observed evidence	Residual risk
Arbitrary session-key payment	Registered digest, exact EIP-712 context and live ERC-1271 checks. Invalid-input and signer tests.	Owner compromise, incorrect token behavior or cryptographic failure remain assumptions.
Concurrent overspend	Atomic root/session reservations and execution tests with concurrent requests.	Honest relayer nonce conflicts and failed gas expense remain possible.
Duplicate purchase after retry	Permanent used step, deterministic nonce and durable order. Same-hash recovery in the public case.	Two distinct owner-approved steps can describe the same real-world service.
Revocation after precheck	Live authority at token settlement and a recorded preverify/revoke rejection case.	Canonically earlier settlement remains paid.
Malicious service metadata	Approved request hash, network/asset/payee/price checks and DNS/Host/redirect controls.	An approved merchant can still withhold service or provide false data.
Payment without delivery	Separate payment, service and result states. Original-order retrieval.	No automatic refund, guaranteed delivery or universal result-quality judgment.
RPC loss, restart or reorg	Pre-broadcast persistence, leases, canonical reconciliation and actual fault tests.	Trusted RPC errors, disk loss, deep reorg or indefinite outage can require intervention.
Altered evidence	Signed checkpoints, salted disclosures, ActionProof links and separate verifier.	A session signer can invent observations without an independent source witness.
Hidden evidence tail	Compare against a separately retained trusted latest root.	An unknown unanchored tail or colluding retention remains undetectable.
Hidden/grinding calls	Durable query cap within the optional controller.	Direct calls outside that interface remain unobserved and unbounded.
Host bypass or key exposure	Financial scope remains on chain. Private runtime permissions and role separation reduce accidental exposure.	Same-host administrator isolation is not provided.
Secret leakage in export	Restricted schemas, safe diagnostic codes and scans against actual private values and nested archives.	Contextual leakage, new credential formats and manual publication mistakes require review.

5. Findings and corrective actions

SA-01: Original Echo bearer credentials were not bound to a final operation. Echo v2 replaces them with role-separated EIP-712 signatures covering the UserOperation and policy/session context. Old credentials do not migrate automatically. Evidence: planning/M2_ACCEPTANCE.zh-CN.md.

SA-02: Echo ABI/decoder checks and validation-time spending did not meet the selected real EntryPoint behavior. The repaired route uses one swap ABI, restricted execution, exact allowance cleanup, execution-time actual input accounting and explicit UserOperation success. Strict public Alto evidence is retained separately from local tests.

SA-03: Canonical recovery could retain a removed transaction or stale service observation after a reorg. The client reconciles block hashes, restores original signed operations where possible and appends outcome observations after the recovered payment checkpoint. Earlier history remains available. Evidence: M4 and M7 operations reports.

SA-04: A prior invariant handler returned without exercising settlement. The harness was corrected with independent balance and reservation checks. This is a coverage correction, not a newly discovered deployed-contract change. Evidence: planning/M3_ACCEPTANCE.zh-CN.md and artifacts/m6/sdk/invariant-harness-regression.json.

SA-05: Malformed private JSON could disclose parser fragments. Startup diagnostics now use safe codes, with actual subprocess canary tests. Public status omits raw signed operations and payment-authorization signatures. Evidence: planning/M7_OPERATIONS_ACCEPTANCE.zh-CN.md.

SA-06: Echo SignerStore accepted truncated GCM authentication tags. A full 16-byte policy and before/after signing regression address the finding. The report does not claim demonstrated private-key extraction or an on-chain authorization bypass. Evidence: competition/STATIC_TOOL_REVIEW.en.md, SR-01.

SA-07: Onboarding state previously hid Local/Testnet choices, resumed progress confusingly and produced connection/workspace routing failures. Independent profiles, explicit progress reset, a bound Guided package and corrected workspace routing have regression evidence. Native Claude import and actual calls were subsequently recorded. Restarting the guide does not undo chain transactions or restore revoked grants. Evidence: planning/M8_ACCEPTANCE.zh-CN.md.

SA-08: The recorded public path experienced an RPC transport failure and a five-minute payment expiry. Diagnostics and same-order reconciliation were improved, and a verified alternate RPC was configured. An explicitly owner-approved replacement task reused the same funded wallet. The original failure remains in recording-history.json. A longer session does not extend the account's immutable 300-second payment window.

SA-09: Same-host key access, off-chain controller bypass, unknown evidence tails, signed installer distribution and persistent local-node recovery remain open boundaries. The standalone public verifier also reports incomplete HTTPS provenance and history. These are release limitations, not checks that passed.

6. Evidence, privacy and dependencies

The verifier's requiredChecksPassed flag concerns required financial and disclosed record checks. It does not mean overall=confirmed. Merchant receipts cover only the fields they sign. They do not independently prove HTTPS origin, amount, request body, result body or truth. Minimal export leaves hidden-result checks incomplete. Amount, recipient and timing remain public on chain, and low-entropy commitments can still permit inference.

The owner key stays outside the production gateway. Session, operator, merchant and connection files remain local and private. The Guided package references a connection rather than embedding the owner key or token payment authorization. Current transport is local stdio and loopback services, not a production multi-tenant custody endpoint. Permission prompts and host installation requirements remain host-controlled.

Solidity, compiler options and dependency commits are pinned. MIT project code retains Echo, Apache-2.0 x402 and other upstream notices. Token proxy/domain changes and facilitator changes require renewed compatibility checks. The source package excludes registration forms, original private proposal materials, private runtime, databases, connection credentials and signed transaction journals.

7. Test evidence and release recommendation

The M7 evidence records 120 eventual HTTP tasks, 132 settlements, zero duplicate payments, eight core/boundary stateful cases and 10,000 distinct explicitly invalid eth_call inputs with legal controls. These finite tests do not establish universal exploit resistance, production throughput or a market-wide ranking. The test protocols and raw rows remain available in the source.

The native Claude/Rabby public case records one successful 0.01 test USDC settlement, same-order recovery and a post-revocation refusal with no additional transaction. Its required financial checks pass, while overall evidence remains incomplete. The workspace verification button lacked a trusted profile, so that report came from the standalone verifier with an explicit trust file.

This release is appropriate for scoped testnet evaluation with separate owner review and limited test funds. Production use requires a renewed threat assessment, external human audit, stronger signer/retention isolation, broader compatibility testing, signed distribution and an operational recovery design. The task checklist retains the remaining usability and release gates. No official competition submission or mainnet operation was performed by preparing these materials.

8. Review sources

Review the technical documentation, competition/STATIC_TOOL_REVIEW.en.md, planning/M7_SECURITY_REVIEW.zh-CN.md, planning/M7_FORMAL_BOUNDARIES.zh-CN.md, planning/M7_OPERATIONS_ACCEPTANCE.zh-CN.md and planning/M8_ACCEPTANCE.zh-CN.md. The current public case is in competition/video/claude-desktop-base-v1/execution-evidence/. The source manifest and clean reproduction report identify the exact exported snapshot separately from historical run fingerprints.